

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

DarkSword «P7»: утёкшая iOS-эксплойт-цепочка на службе кражи криптокошельков

iOS Exploit Chain • Drive-by • Кража keychain и кошельков • DarkCoruna • Киберкриминал

Параметр	Значение
Дата анализа	10 октября 2026
Классификация	Drive-by iOS-эксплойт-цепочка (6 CVE) + стилер keychain / криптокошельков
Уровень угрозы	ВЫСОКИЙ
Актор	Неатрибутированный китайязычный криминальный кластер («qqtime»), средняя уверенность
Участие государства	Признаков нет. Построено на публичной утечке DarkSword марта 2026
ВПО	DarkSword (утёкшая сборка), загрузчик Coruna, имплант P7 (библиотека GHOSTBLADE + переписанный агент)
Цели	Пользователи iPhone, заходящие на китайязычные страницы казино, крипто и «iOS-сервисов»
Затронутые системы	iOS 18.4 – 18.7 (DarkSword); iOS 13 – 17.2.1 (Coruna, с той же страницы)
Исправлено в	iOS 18.7.3 / 26.2 (CVE-2026-20700 — iOS 26.3)
CVE	CVE-2025-31277, CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520
Источники	Только публичные песочницы и данные пассивного DNS (urlscan.io, tria.ge, MWDB, VirusTotal); публикации iVerify и GTIG

1. Краткое заключение

DarkSword — полная эксплойт-цепочка для iOS, целиком написанная на JavaScript: один визит на веб-страницу с iOS 18.4–18.7 даёт удалённое выполнение кода, выход из песочницы, повышение привилегий в ядре и внедрение импланта-стилера в системные процессы. Google Threat Intelligence Group (GTIG) описала её в марте 2026 года в руках трёх заказчиков шпионского профиля; 22 марта 2026 исходный код одной из сборок утёк на GitHub, и цепочка разошлась по криминальной среде. 8 октября 2026 iVerify описала криминальный вариант под именем «P7»: имплант с префиксом p7_, двусторонним каналом управления и разбором keychain прямо на устройстве, доставляемый с доменов gotoiphone[.]com и mzp30[.]cam.

Этот отчёт добавляет то, что можно установить о P7 и стоящей за ним операции по одним только открытым данным. Работая исключительно с пассивными источниками — публичными сканами urlscan.io, публичной отправкой на tria.ge, репозиторием MWDB CERT Polska и метаданными VirusTotal — и не обращаясь к живой инфраструктуре злоумышленников, мы восстановили третью, ранее не описанную сборку P7, полную цепочку доставки и кластер связанных развёртываний, уходящий в июль 2026 года.

Ключевые результаты:

- В публичной отправке в песочницу найдена третья сборка P7, датированная 29 сентября 2026. Она отдаётся с приманки — китайского онлайн-казино [www.iospc8\[.\]com](http://www.iospc8[.]com) — и отчитывается новому серверу управления (C2) [www.y21t8bcya6q9b7155a\[.\]cc](http://www.y21t8bcya6q9b7155a[.]cc). Ни того, ни другого нет в списке индикаторов iVerify. В агенте зашит «код канала» — признак партнёрской модели распространения.
- P7 — не переписанный DarkSword. Его низкоуровневая библиотека и загрузчик байт-в-байт совпадают с имплантом GHOSTBLADE, который GTIG приписывает самим разработчикам DarkSword; новое в нём — полностью переписанный агент управления и новая стадия расшифровки keychain, превращающая собственный AppleKeyStore устройства в оракул расшифровки.
- Хост доставки [cdn.gotoiphone\[.\]com](http://cdn.gotoiphone[.]com) из списка iVerify отдаёт не только DarkSword, но и загрузчик Coruna для старых iOS — из одного скрытого iframe, то есть это комбинированное развёртывание «DarkCoruna». Тот же загрузчик, узнаваемый по фиксированной соли и обфускатору, с 16 июля 2026 встречается ещё на пяти хостах под именем проекта «qqtime».
- Из 185 хешей файлов в приложении к посту iVerify на VirusTotal есть только 38 (21 %), в MalwareBazaar — ни одного. Блокировка по хешам не является эффективной защитой от этого семейства; детект должен опираться на файловые артефакты, сетевые паттерны и строки кода — для них мы приводим черновые YARA-правила.
- Всё в операции — приманки-казино и крипто, кража ключей кошельков imToken и TokenPocket, телеметрия посетителей в духе рекламного трекера, коды каналов, китайские комментарии в коде — указывает на финансово мотивированный криминал. Признаков государственного заказа у P7 нет. Сама же эксплойт-цепочка до утечки была инструментом государственного уровня.

2. Контекст

2.1. DarkSword до утечки

Отчёт GTIG «The Proliferation of DarkSword» от 18 марта 2026 описывает цепочку и трёх её пользователей: UNC6748 (Саудовская Аравия, ноябрь 2025, бэкдор GHOSTKNIFE), турецкого коммерческого вендора слежки PARS Defense (Турция и Малайзия, бэкдор GHOSTSABER) и UNC6353 — предположительно российскую шпионскую группу, проводившую атаки типа watering hole на украинские сайты сначала с Coruna, а с декабря 2025 — с DarkSword и датамайнером GHOSTBLADE. По оценке GTIG, GHOSTBLADE, вероятно, написали сами разработчики DarkSword. Разработчик публично не назван; картина нескольких несвязанных заказчиков характерна для продукта, продаваемого через брокера или вендора эксплойтов.

Цепочка использует шесть уязвимостей, три из которых на тот момент были нулевого дня: CVE-2025-31277 и CVE-2025-43529 (RCE в JavaScriptCore для iOS младше и старше 18.6), CVE-2026-20700 (обход PAC в dyld), CVE-2025-14174 (ANGLE, из WebContent в GPU-процесс), CVE-2025-43510 (XNU, из GPU в mediaplayerbackd) и CVE-2025-43520 (гонка в XNU VFS, ядро). Apple закрыла их в iOS 18.7.2, 18.7.3, 26.1, 26.2 и 26.3.

2.2. Утечка и криминальная волна

22 марта 2026 полная сборка — кит UNC6353 вместе с GHOSTBLADE — была опубликована на GitHub. Через несколько дней её переразвернули другие акторы, включая российскую государственную группу TA446 / Star Blizzard против гражданского общества (наш отчёт от 28 марта 2026). К сентябрю 2026 iVerify насчитывала порядка 17 000 доменов с вариантами DarkSword и Coruna второго поколения и ввела термин «DarkCoruna» для развёртываний, объединяющих обе цепочки и покрывающих все iPhone от iOS 13 до 18.7.

2.3. P7 в описании iVerify

Пост iVerify «Sleep, Beacon, Steal, Repeat» от 8 октября 2026 описывает P7 по устройству клиента: имплант в SpringBoard, который каждые 15 секунд шлёт beacon по HTTP/1.0 на /beacon, принимает команду sleep, выгружает данные на /result, /a, /event, /u, /nb, /p и /war, использует зашитый user agent iOS 18.5 и фиксированную multipart-границу и разбирает keychain в JSON на устройстве. Хосты доставки — cdn.gotoiphone[.]com и mzp030[.]cam; серверы управления — agdx53[.]cc и js.gotoiphone[.]com. iVerify опубликовала хеши десяти компонентов P7; на момент нашего анализа на VirusTotal были только два из них, а сам агент не был доступен нигде.

3. Объём и метод

Весь материал отчёта получен пассивно. Мы не подключались ни к одному хосту злоумышленников.

Источники:

- urlscan.io: публичные сканы страниц-приманок с сохранёнными телами ответов, полученными через API по хешу ответа. Там, где возможно, восстановленные тела сверены с независимыми хешами краулеров.
- tria.ge: публичная отправка от 3 октября 2026 с архивом полного кита DarkSword.
- MWDB CERT Polska: образец GHOSTBLADE, опубликованный GTIG, и сентябрьский кит DarkSword из фида MalwareBazaar — как базы для сравнения.
- VirusTotal, Hybrid Analysis, AlienVault OTX и Validin — для метаданных (даты первого появления, пассивный DNS, WHOIS, нечёткие хеши). Ни один файл никуда не загружался.

Весь анализ кода — статический, в изолированной среде, без исполнения JavaScript в средах на базе WebKit или JavaScriptCore.

4. Результат 1: третья сборка P7

ZIP-архив test.zip (SHA-256 ef9263b1..., 437 КБ) был отправлен в публичную песочницу tria.ge 3 октября 2026. Внутри — полное развёртывание DarkSword с файлами, датированными 29 сентября 2026. Песочница классифицировала его обобщённо; VirusTotal помечает как trojan.darksword.

Файл	Размер	Роль
index.html	51 385 Б	Приманка: китайское онлайн-казино «通博娱乐 – www.iospc8.com», ссылки на ub555[.]net / ub11[.]org (бренд казино-браузера)
jmp.html	2 215 Б	Запускатель: пять скрытых iframe с шагом 1,5 с, блокировки в sessionStorage (rce_locked, uid), автоповтор через 45 с
0kio7x2igj0bp79owd.html	836 Б	Сторож: перезагружает страницу, если эксплойт завис
rce_loader.js	7 318 Б	Селектор стадий в стиле утёкшего кита с включённой телеметрией (SERVER_LOG = true, /log.html) и редиректом на /406.html для неподходящих устройств
rce_module.js	173 079 Б	RCE-модуль CVE-2025-31277 — SHA-256 92c7d246..., не менялся со сборок UNC6353 / TA446 / GitHub
rce_worker_18.4.js / 18.6.js	45 КБ / 520 КБ	Эксплойт-воркеры для iOS 18.4–18.5 и 18.6–18.7
sbx0_main_18.4.js / sbx1_main.js	400 КБ / 310 КБ	Выходы из песочницы
pe_main.js	793 879 Б	Эксплойт ядра + бандл импланта. На 15 КБ больше утёкшего оригинала: здесь и живёт P7

Домен приманки iospc8[.]com зарегистрирован 23 сентября 2026 (GoDaddy, DNS Cloudflare) — за шесть дней до сборки кита. Сервер управления www.y21t8bcsya6q9b7155a[.]cc зарегистрирован 25 мая 2026 через Gname.com с китайской страной регистранта, стоит за Cloudflare и до переноса за

CDN недолго резолвился в адрес Alibaba Cloud в Гонконге. Ни того, ни другого домена в индикаторах iVerify нет.

Заголовок конфигурации агента гласит: «C2 Agent Payload – persistent loop in SpringBoard. Communicates with command.py via HTTP ... replaced by server.py at load time». Серверная часть, таким образом, — приложение на Python, подставляющее URL сервера управления в имплант при отдаче. В конфигурации есть и константа C2_CHANNEL_CODE, отправляемая полем source в каждом запросе регистрации, heartbeat и инвентаризации. Тот же механизм — параметр channelcode в URL загрузчика — есть и в кластере доставки из раздела 6. Кодами каналов партнёрские программы учитывают трафик; их наличие означает, что кит эксплуатируется как сервис для нескольких распространителей, а не одним конечным пользователем.

5. Результат 2: что на самом деле меняет P7

5.1. Сравнение с GHOSTBLADE по модулям

ре_main.js — webpack-бандл. Помимо библиотеки эксплойта он содержит четыре payload-модуля импланта в виде строк: loader.js, c2_agent.js, keychain_copier.js и MigFilterBypassThread.js. Мы извлекли их и сравнили каждый с соответствующим модулем внутри образца GHOSTBLADE, опубликованного GTIG (SHA-256 2e5a56be...).

Модуль	GHOSTBLADE (GTIG)	P7, сборка 3	Вердикт
loader.js	10 096 Б	10 096 Б, SHA-256 d554f534...	Байт-в-байт тот же файл. «Загрузчик P7» в публичных списках хешей — это оригинальный загрузчик GHOSTBLADE, отсюда ноль детектов на VirusTotal
MigFilterBypassThread.js	3 797 строк	3 797 строк, SHA-256 48aacf46...	Идентичный код; отличается только форматирование закрывающих скобок. Тот же хеш в обеих сборках P7 у iVerify
keychain_copier.js	350 строк	360 строк, SHA-256 f0f0aa82...	Версия GHOSTBLADE плюс файлы WAL/SHM базы keychain-2.db и база Apple Notes
file_downloader.js → c2_agent.js	3 740 строк, одноразовая выгрузка на sqwas.shapelie[.]com с заголовком X-Device-UUID	4 756 строк, SHA-256 38975537...	Переписан: уцелел только вспомогательный класс Native (2,5 % общих строк). Сборщики Telegram, WhatsApp, iCloud, WiFi и SMS из GHOSTBLADE удалены
wifi_password_dump.js, wifi_password_security_d.js, icloud_dumper.js	есть	нет	Удалены. Вместе с ними исчезли все строки YARA-правила

			GTIG G_Datamine_GHOSTB LADE_1
--	--	--	-------------------------------------

Иначе говоря, авторы P7 оставили сложную часть DarkSword — библиотеку удалённых вызовов TaskRop и обход MIG-фильтра — нетронутой и заменили прикладную логику. Это согласуется с наблюдением iVerify, что правки демонстрируют компетентность, а не машинную генерацию, но означает и то, что «новый» имплант делит большинство байтов с утёкшим.

5.2. Агент управления

c2_agent.js внедряется в SpringBoard и работает до перезагрузки. Он регистрирует устройство (/a), затем в цикле каждые 15 секунд отправляет beacon с {uuid, device_info, status: "idle"}, выполняет полученную команду и отправляет результат на /result с идентификаторами команды и задачи. Команда sleep меняет интервал. Транспорт — HTTP/1.0 через CFStream с kCFStreamSSLValidatesCertificateChain = false, то есть принимается любой сертификат; user agent — зашитая строка Safari под iOS 18.5.

Отдельные обработчики: basic_info, disk_scan, ios_app_data, wallet_extract, wallet_scan, memo_scan, photo_scan, photos, apps, download, upload, file_upload, exec, eval, execute_command, sleep, exit. Обработчик execute_command реализует около пятидесяти shell-подобных подкоманд (ls, cat, find, grep, ps, netstat, ifconfig, hexdump, memdump, httpsy и другие), давая оператору интерактивный доступ к файловой системе, списку процессов и сетевым соединениям без оболочки.

Прицел на кошельки явный. Агент находит контейнеры приложений по bundle identifier для imToken, TokenPocket, Trust Wallet, Bitget / BitKeep, Phantom, Solflare, Uniswap, Tonhub, Bitpie и TronLink, читает базы React Native AsyncStorage, а для imToken расшифровывает Ethereum keystore v3 прямо на устройстве (PBKDF2, AES-CTR, HMAC-SHA256 реализованы на JavaScript), используя пароль, найденный в расшифрованном keychain. Результат упаковывается вместе с дампом keychain и отправляется на /war.

5.3. «P7 Phase 2»: оракул keychain

По-настоящему новая инженерия находится не в агенте, а в самом pe_main.js, в блоке, который авторы называли «P7 Phase 2: V4 Local SQLite + Remote AKS Oracle Pipeline» (AKS — AppleKeyStore). После эксплойта ядра pe_main.js внедряет keychain_copier.js в configd (тот копирует keychain-2.db и keybag-файлы в /tmp), а loader.js и c2_agent.js — в SpringBoard. Затем он «будит» securityd тремя вызовами SecItemCopyMatching, устанавливает канал удалённых вызовов в securityd, из контекста securityd открывает IOKit-сервис AppleKeyStore и использует aks_unwrap как оракул для разворачивания классовых ключей элементов, прочитанных из локальной копии базы keychain. Расшифрованные элементы записываются в /private/var/tmp/keychain_c2_dump.json, затем создаётся четырёхбайтовый маркер .done, который агент опрашивает до 180 секунд, прежде чем собрать пакет кошельков.

GHOSTBLADE лишь копировал файлы keychain на сервер. P7 расшифровывает их на устройстве, поэтому его выгрузка может быть маленькой, прицельной и сразу пригодной к использованию. У этой фазы собственный журнал — /private/var/tmp/p7_debug.log, который пишется буферизованной процедурой fopen/fwrite; ветка кошельков в агенте пишет /private/var/tmp/c2_wallet_debug.log.

Утверждение iVerify, что P7 убрал отладочное логирование, относится только к логированию по HTTP и в syslog; файловое логирование сделано намеренно и является надёжным криминалистическим артефактом.

5.4. Криминалистические артефакты

Путь	Кто пишет	Содержимое
/private/var/tmp/ keychain_c2_dump.json (.tmp, .done)	pe_main.js, Phase 2	Расшифрованные элементы keychain в JSON; маркер .done
/private/var/tmp/p7_debug.log	pe_main.js, Phase 2	Журнал хода конвейера keychain
/private/var/tmp/ c2_wallet_debug.log	c2_agent.js	Трассировка упаковки и выгрузки кошельков («[WALLET-HQ]»)
/private/var/tmp/ imtoken_keychain.json	c2_agent.js	Результат извлечения keystore imToken
/private/var/tmp/_hq_notestore (- wal, -shm); /private/var/tmp/notes.sqlite*	c2_agent.js; keychain_copier.js	Копии базы Apple Notes
/private/var/tmp/keychain-2.db*, persona.kb, usersession.kb, System.keybag, Backup.keybag	keychain_copier.js	База keychain и keybag-файлы (унаследовано от GHOSTBLADE)
/var/mobile/Library/Caches/ ios_disk_scan.txt; /var/mobile/ios_disk_scan.txt	c2_agent.js	Вывод disk_scan, выгружается частями и удаляется

6. Результат 3: кластер доставки «qqtime»

6.1. Восстановление живой цепочки из urlscan

Крипто-новостной сайт cryptonewstrack[.]com публично сканировался на urlscan.io 17 июля, 5 сентября и 15 сентября 2026. Два сентябрьских скана захватили полную цепочку доставки P7, кроме финальной стадии, которая отдаётся только при строке User-Agent, указывающей на iOS 18. Тела ответов извлечены из хранилища urlscan; SHA-1 восстановленного group.html совпадает с хешем тела, независимо зафиксированным краулером Validin 19 сентября.

- Страница загружает hxxps://oss.gotoiphone[.]com/alicdn/a5a62a47e2914d88ab7b34b2ebea8b25.js (2 660 Б) из объектного хранилища Alibaba.
- Этот скрипт создаёт скрытый iframe 1×1 на hxxps://cdn.gotoiphone[.]com/group.html и каждые пять секунд отправляет публичный IP посетителя, версию ОС и URL страницы на hxxps://goo[.]wang/alicdn/a5a62a47.../visit. goo[.]wang резолвится в тот же адрес Alibaba Cloud, что и js.gotoiphone[.]com — сервер управления P7 из поста iVerify.
- group.html (комментарии на китайском) загружает loader.js для каждого посетителя и, если user agent содержит «18», дополнительно rce_loader.js — точку входа DarkSword. Страница перезагружает себя каждые 120 секунд.
- loader.js (47 605 Б) — не DarkSword. Это обфусцированный загрузчик Coruna: таблица модулей с ключами SHA-1, догрузка модулей по именам вида SHA-256(соль + имя), соль secd08aa6ff548c2, пороги версий iOS 13.0 и 16.0, коды результата 1000/1001/1003, отправляемые на сервер. cdn.gotoiphone[.]com, таким образом, — развёртывание DarkCoruna: Coruna для iOS 13–17.2.1, DarkSword для 18.x, из одного iframe. В посте о P7 половина с Coruna не упоминается.

6.2. Тот же загрузчик с июля

Загрузчик Coruna достаточно необычен, чтобы по нему пивотить. Поиск в urlscan по заголовку страницы, имени файла и соли даёт ту же сборку — те же имена функций, таблица модулей, соль и константы — ещё на пяти хостах:

Впервые	Хост / путь	Наблюдение
2026-07-16	iphone.apiforx[.]work/qqtime/qqtime.html; 1x8gmjbdq3tepgr[.]jicu/	Загрузчик 34ef644f....js, результаты на 1x8gmjbdq3tepgr[.]jicu/api
2026-07-17	cryptonewstrack[.]com/qqtime/34ef644f....js	Загрузчик лежит на самом сайте-приманке, результаты на ipsadminuser[.]shop/api
2026-07-31	1.aivestorix[.]com/qqtime/qqtime.html	Тот же файл, что на cryptonewstrack
2026-08-04	billowing-truth-804c.pages[.]dev/1df7afe3.../foxtimes + routers.js	routers.js: iOS ≥ 18.4 → ds_rce_loader.js, иначе загрузчик Coruna с ? channelcode=1df7afe3... — первое появление ветки DarkSword
2026-09-05 → 2026-10-03	cdn.gotoiphone[.]com	group.html → загрузчик Coruna + rce_loader.js; с 28 сентября индексная страница снова

		называется «qqtime» и ссылается на routers.js
--	--	--

Имя проекта у оператора читается открыто — «qqtime» (каталог, заголовок страницы); одно из развёртываний названо «foxtimes». Параметр channelcode в routers.js равен имени каталога развёртывания, то есть у каждого распространителя свой путь. Сам gotoiphone[.]com — спящий домен (последняя активность в 2020 году), перерегистрированный 28 июля 2026 через Dominet (HK) с DNS Alibaba; поддомен доставки переехал на Alibaba OSS 5 сентября. Ни одного из этих хостов, как и cryptonewstrack[.]com, ipsadminuser[.]shop и goo[.]wang, нет в списках индикаторов iVerify и GTIG, а восстановленных файлов нет на VirusTotal.

Является ли cryptonewstrack[.]com (зарегистрирован 18 мая 2026, одним вендором отнесён к «phishing and fraud») взломанным сайтом или приманкой под контролем оператора, установить не удалось; его следует рассматривать как приманку, а не блокировать как инфраструктуру.

6.3. Общий бэкэнд?

Корневая страница mzро30[.]com — второго хоста доставки P7 у iVerify — возвращает 49-байтовую заглушку (<p>.</p>) с заголовками Server: openresty, Cache-Control: no-cache, no-store и Access-Control-Allow-Origin: * за CloudFront. Корень nuih22[.]cc — DarkSword-хоста, обслуживающего в приложении iVerify 14 разных приманок, — возвращает идентичное тело и те же заголовки за Cloudflare, и оба используют путь /assets/js/group.html. 49-байтовая заглушка — слабый отпечаток, поэтому наличие общего оператора или общего шаблона кита мы оцениваем лишь со средней уверенностью.

7. Результат 4: экосистема DarkSword в цифрах

Приложение iVerify содержит 229 пар «приманка — бэкэнд DarkSword», 185 хешей компонентов и 48 URL управления, собранных через Validin. Их кластеризация:

- Хосты-приманки: 190 доменных имён и 39 голых IP-адресов, 25 из них на нестандартных портах (8080, 8000, 8888) — тестовые стенды операторов. Домены верхнего уровня: .top — 87, .com — 36, .icu — 12, .site — 10, .cc — 9.
- Имена — pinyin-мусор вокруг китайских потребительских брендов (guge = Google, youdao, sougou, meitu, музыка qishui, leidian, feiji = Telegram), семейство казино (cgwin*, 10 доменов), крипто (catcoinglobal[.]top, web3a[.]cc, hi-metaverse[.]online) и поддельные «iOS-сервисы».
- Бэкэнды: 114 приманок хостят кит сами; 94 (41 %) загружают его с одного хоста cf.r5dz2dz88wuideu[.]xyz, ещё 14 — с nuih22[.]cc. Примерно половина «17 000 доменов» — одноразовые витрины одного-двух общих бэкэндов: платформа, а не толпа.
- URL управления идут парами — http на 8882 и https на 8881 — схема портов утёкшего сервера GHOSTBLADE. P7 от неё отказался в пользу 443 за Cloudflare.
- Публичная видимость: 38 из 185 хешей на VirusTotal (загрузчики — 4 из 49, pe_main — 6 из 35), отправки растянуты с марта по октябрь 2026; у шести из 38 — ноль детектов. MalwareBazaar по тегу — ничего. Hybrid Analysis — ничего. Кит пересобирается под каждый хост; списки хешей отстают на месяцы.

8. Оценка атрибуции

Со средней уверенностью мы оцениваем P7 и кластер qqtime как работу китаеязычной финансово мотивированной группы, эксплуатирующей сервис доставки эксплойтов для нескольких распространителей. В пользу этого: приманки казино и крипто для китаеязычной аудитории; функциональность импланта, сосредоточенная на краже seed-фраз кошельков и keychain; коды каналов и в загрузчике, и в импланте; телеметрия посетителей, типичная для трафик-брокеров; китайские комментарии в страницах доставки; одноразовые домены через Gname и GoDaddy за Cloudflare, CloudFront и Alibaba.

Признаков участия государства в P7 мы не находим. Довод «вредоносное ПО под iOS редко, значит, это государство» больше не работает: после утечек Corona и DarkSword полные iOS-цепочки стали товаром, и iVerify фиксирует следы заражения на 5 % устройств, остающихся на уязвимых версиях. Инструментом государственного уровня здесь является только сама эксплойт-цепочка, которой до утечки пользовались три заказчика шпионского профиля; её исходный разработчик публично не атрибутирован.

Поправка к нашему собственному отчёту от 28 марта 2026: инфраструктура static.cdncounter[.]net и sqwas.shapeliel[.]com, которую мы называли «исходной инфраструктурой DarkSword (UNC6748)», по данным GTIG принадлежит UNC6353, а GHOSTBLADE — обозначение GTIG, а не Proofpoint. TA446 переиспользовал утёкший кит UNC6353 вместе с его сервером выгрузки; это две разные группы.

9. Обнаружение

9.1. YARA

Правило GTIG G_Hunting_DarkSwordExploitChain_ImplantLib_FilePaths_1 срабатывает на бандл ре_main.js P7 (webpack-пути исходников сохранены), но не на извлечённый агент;

G_Datamine_GHOSTBLADE_1 на P7 не срабатывает вовсе. Приведённые ниже черновые правила проверены на одной сборке P7 с нулём ложных срабатываний на GHOSTBLADE, сентябрьском ките DarkSword и восстановленных страницах доставки и предназначены для хантинга. Перед использованием в блокирующем режиме их нужно перепроверить на других сборках.

P7_DarkSword_C2Agent_Strings — строки: "p7_" (более 20 вхождений), "-----HqBound", "/beacon", "/war", "/nb", "keychain_c2_dump", "p7_debug.log", "c2_wallet_debug.log", "_hq_notestore", "ios_disk_scan.txt", "wallet_scan", "memo_scan", "execute_command", "disk_scan", "iPhone OS 18_5 like Mac OS X". Условие: файл меньше 10 МБ, не архив и не исполняемый, и (p7_ более 20 раз, или HqBound, или два из путей артефактов) и три из строк эндпоинтов / команд / UA.

P7_DarkSword_LocalStorage_Markers (страницы доставки) — строки: "lab_device_uuid", "__ds_inflight_worker", "__ds_skip_workers", "_x_pe_done", "cecd08aa6ff548c2", "obChTK", "ds_rce_loader.js", "34ef644ff217a50beadde64dc8e23a7d". Условие: файл меньше 2 МБ и два ключа localStorage или два маркера qqtime.

9.2. Сеть

- POST-запросы HTTP/1.0 с iPhone на /beacon каждые 15 секунд и на /a, /event, /u, /nb, /p, /war того же хоста; multipart-граница -----HqBound; JSON-поля lhu, source (32-символьный hex-код канала), channel_code.
- TLS-сессии из кода в контексте SpringBoard, принимающие любой сертификат (без проверки цепочки), к недавно зарегистрированным доменам .cc / .cam / .lol за Cloudflare.
- На веб-стороне: скрытые iframe на */group.html, скрипты с именами rce_loader.js, ds_rce_loader.js, routers.js, запросы к */api с параметром channelcode и периодические POST с полями visitorIp / deviceVersion / sourceUrl.

9.3. Хост

Пути артефактов из раздела 5.4 сохраняются до перезагрузки или зачистки и видны в sysdiagnose или образе файловой системы. На стороне браузера после атаки остаются ключи localStorage lab_device_uuid, __ds_inflight_worker, __ds_skip_workers (сборка gotoiphone) и _x_pe_done, _x_try, _x_ok (сборка mzp30), по которым можно определить, какое развёртывание посетило устройство.

10. Индикаторы компрометации

Индикаторы с пометкой «iVerify» повторены из публикации вендора для полноты; все остальные впервые приводятся в этом отчёте. Адреса общих облачных сервисов даны только для контекста и блокировать их нельзя.

10.1. Домены и хосты

Индикатор	Роль	Примечание
www.y21t8bcsya6q9b7155a[.]cc	C2 P7 (сборка 3)	Gname, CN, 2026-05-25, Cloudflare; эндпоинты /beacon /result /a /event /u /nb /p /war
iospc8[.]com	Приманка P7 (сборка 3)	Казино «通博娱乐», GoDaddy, 2026-09-23, Cloudflare
agdx53[.]cc	C2 P7	iVerify; Gname, CN, 2026-06-09, Cloudflare
js.gotoiphone[.]com	C2 P7	iVerify; Alibaba Cloud 47.237.185.24
cdn.gotoiphone[.]com	Доставка DarkCoruna	iVerify; Alibaba OSS; group.html, loader.js, rce_loader.js
mzpo30[.]cam	Доставка P7	iVerify; Gname, CN, 2026-08-17, CloudFront + openresty
oss.gotoiphone[.]com	Хост инжектора	alicdn/a5a62a47e2914d88ab7b34b2eb ea8b25.js
gotoiphone[.]com	Апекс кластера	Перерегистрирован 2026-07-28, Dominet HK, alidns
goo[.]wang	Телеметрия посетителей	Тот же IP, что у js.gotoiphone[.]com
ipsadminuser[.]shop	Эндпоинт отчёта загрузчика (июльская сборка)	Cloudflare, с 2026-04-25
1x8gmjbdq3tepgr[.]jicu	Хост загрузчика Coruna + /api	2026-07-16
iphone.apiforx[.]work	Хост загрузчика Coruna	2026-07-16, /qqtime/
1.aivestorix[.]com	Хост загрузчика Coruna	2026-07-31, /qqtime/
billowing-truth-804c.pages[.]dev	Роутер DarkCoruna («foxtimes»)	2026-08-04
cryptonewstrack[.]com	Сайт-приманка	Взломан или принадлежит оператору — не установлено;

		не блокировать как C2
nuih22[.]cc	Общий бэкенд DarkSword	Приложение iVerify; тот же отпечаток корня, что у mзpo30[.]cam
66ds[.]lol	Связан с P7 (OTX)	Не подтверждён; NameSilo, 2026-06-03

10.2. URL

URL	Роль
hxxps://www.y21t8bcya6q9b7155a[.]cc/beam	Выдача команд P7
hxxps://www.y21t8bcya6q9b7155a[.]cc/war	Выгрузка keychain и кошельков P7
hxxps://oss.gotoiphone[.]com/alicdn/a5a62a47e2914d88ab7b34b2ebea8b25.js	Инжектор
hxxps://cdn.gotoiphone[.]com/group.html	Страница-роутер DarkCoruna
hxxps://cdn.gotoiphone[.]com/loader.js	Загрузчик Coruna
hxxps://goo[.]wang/alicdn/a5a62a47e2914d88ab7b34b2ebea8b25/visit	Телеметрия
hxxps://ipsadminuser[.]shop/api	Эндпоинт отчёта загрузчика
hxxps://1x8gmjbdq3tepgr[.]jicu/api	Эндпоинт отчёта загрузчика

10.3. IP-адреса (только контекст)

IP	Контекст
47.237.185[.]24	Alibaba Cloud: gotoiphone[.]com, js.gotoiphone[.]com, goo[.]wang с 2026-08-10
47.79.48[.]200	Общий эндпоинт Alibaba OSS (cdn.gotoiphone[.]com и ~60 посторонних доменов) — не блокировать
47.242.129[.]133	Origin www.y21t8bcya6q9b7155a[.]cc до Cloudflare, 2026-05-25 — исторический

10.4. Файлы (SHA-256)

Файл	SHA-256	Примечание
test.zip	ef9263b1a74e80d55331763335847017efba9018401b037c66729b265c255bb7	Архив кита P7, сборка 3
pe_main.js	57c3997642882815e02bcc50b60a63292dc3f5ed0337f2dd0c9c93b34a423a08	Бандл импланта P7, сборка 3

TLP:CLEAR

c2_agent.js	38975537d2c66815484a1adb01b681bffa96168cd6e9474e24815ad4a4796127	Агент P7, сборка 3 (новый)
loader.js	d554f534fad7822cbde9ca7d9f6efe8a7e0f5786ccee60f8db6dad340a2a6f80	= загрузчик GHOSTBLADE; iVerify
keychain_copier.js	f0f0aa82a03bf4835864a5b7f7ba38e537f3f81e82b3db311ac0d80b4b4b022e	iVerify (сборка mzpo30)
MigFilterBypassThread.js	48aacf46ad8b7f619d7f4346c330abfbda14a34ed3eb98c215a5ef5fb36e2171	Общая библиотека; iVerify
rce_loader.js	443045e0c3ffdabddaf1fd2d88e93b0e6f614654788fbc1d4f646a4fdc736a6d	P7, сборка 3
rce_module.js	92c7d246d2c163c076f783dcc19f87f5b9b9ac301b106b87a7aaea9346ce0052	Не менялся с утечки
rce_worker_18.4.js	14882fb0baef0f6f45decc79e34d488cdccc15fda505e5b615c5c420a7a8826e	P7, сборка 3
rce_worker_18.6.js	2415b9273b37a04c63bb2e45e81aad86d1b6a7a64a385e0a21377b24e6525245	P7, сборка 3
sbx0_main_18.4.js	d4aa9a78c9e4fb050abdf15da3ae166564f2fda6de63412bac36bc01a0984c21	P7, сборка 3
sbx1_main.js	2748a8fd029c7a55f3107563c8f7993d3deb609d16c4898be0a5609e66a7163d	P7, сборка 3
jmp.html	cf2262d8d064fef3c0fd79018ddd3f2f0e5e827aabb20aa5b6abeebd890ca5f7	Запускатель P7, сборка 3
group.html	fe767e3c7bcb5c9e241334054424333d95ce86fe0e07717ee9ca529dade6930d	Страница-роутер cdn.gotoiphone[.]com
loader.js (Coruna)	20c49dd361181210fade5de43e1c8c4c59485b4f565007b4ca3552	cdn.gotoiphone[.]com, сентябрьская сборка

	b71c7683be	
a5a62a47e2914d88ab7b34b2eb ea8b25.js	b693b028e66e734b4552e0c95b af77d353f5fe178ba363594a157 d6211751fdf	Инжектор
34ef644ff217a50beadde64dc8e2 3a7d.js	5bc7ce2af4fb5e62b801dec719c 0dc90b5deddf0ccd0ac1d6610f8 679d10fd47	Загрузчик Coruna, июль (cryptonewstrack, aivestorix)
34ef644ff217a50beadde64dc8e2 3a7d.js	0d70b4c36967dc3740ee08993f9 abe43693c1e92c8a9c1f25c2183 57307ced82	Загрузчик Coruna, июль (apiforx, 1x8gm...)
routers.js	2eb359647852ae87e4a4de7adc 741abb2889896bf9bda476c647f b075ffb967e	Роутер DarkCoruna, pages.dev

10.5. Строки

Значение	Смысл
f94ed1edc290119993125d85c1106796	Код канала P7, сборка 3
1df7afe33d3bf512f124136cf405f57a	channelcode qqtime (развёртывание pages.dev)
cecd08aa6ff548c2	Соль загрузчика Coruna, все сборки qqtime
-----HqBound	Multipart-граница P7
obChTK, ds_rce_loader.js, qqtime, foxtimes	Глобальный объект загрузчика, файл ветки DarkSword, имена проектов

11. Рекомендации

- Обновиться до iOS 18.7.3 либо до iOS 26.3 или новее; CVE-2026-20700 исправлена только в iOS 26.3. Устройства с iOS 13–17.2.1 уязвимы для Coruna-половины страницы DarkCoruna, устройства с iOS 18.4–18.7.2 — для DarkSword-половины.
- Включить Lockdown Mode для пользователей из группы риска: он блокирует точки входа JavaScriptCore, используемые обеими цепочками.
- На управляемых устройствах искать артефакты из раздела 5.4 и ключи localStorage из раздела 9.3; достаточно sysdiagnose.
- В сети поднимать тревогу по паттерну beacon HTTP/1.0 и границе HqBound, а не по спискам доменов: домены меняются еженедельно, протокол не менялся на протяжении трёх сборок.
- Фиды хешей по этому семейству считать малоценными: пересборка под каждый хост означает уникальные эксплойт-файлы в каждом развёртывании; постоянным остался только rce_module.js.
- Пользователям криптокошельков на iPhone следует считать скомпрометированными любые seed-фразы и хранилища ключей imToken, TokenPocket, Trust Wallet, Bitget, Phantom, Solflare, Uniswap, Tonhub, Bitpie или TronLink на устройстве, посещавшем такие страницы, и перевыпустить ключи на чистом устройстве.

12. Источники

- iVerify, «Sleep, Beacon, Steal, Repeat: P7 DarkSword Variant», 8 октября 2026 (iverify.com/blog/darksword-variant-threat-research)
- iVerify, «Proliferation of Coruna and DarkSword», 15 сентября 2026 (iverify.com/blog/proliferation-of-coruna-and-darksword)
- Google Threat Intelligence Group, «The Proliferation of DarkSword», 18 марта 2026 (cloud.google.com/blog/topics/threat-intelligence/darksword-ios-exploit-chain)
- Lookout, исследование iOS-эксплойт-цепочки DarkSword, март 2026
- FDC Threat Intelligence, «TA446 / Star Blizzard Deploys DarkSword iOS Exploit Kit», 28 марта 2026
- Сканы urlscan.io 01a0a6ab-ccc6-772b-a3d1-7c4143af206a, 01a07386-7b25-7299-bfac-dc7cdfe1bc5d, 019f71b4-d416-75a7-a8c2-96b4a1e31882, 019fce1d-6727-721e-9196-3446ba562239, 019f68b8-71b5-7707-b7fc-0d2b71a852dd, 019f6a90-cedb-701e-a9c3-c43bf7dbb731, 019fb9ec-10c8-717e-b4c2-d93a5776cbb4
- Образец tria.ge 261003-v7ayastdmb (test.zip), отправлен 3 октября 2026
- MWDB CERT Polska, образец GHOSTBLADE 2e5a56beb63f21d9347310412ae6efb29fd3db2d3a3fc0798865a29a3c578d35
- Пульсы AlienVault OTX 6ac8ae8dadff0d3e088c3764, 6a95df86eed3f6fb54baef2d

TLP:CLEAR — Этот документ может распространяться без ограничений.